Homelab Ops Audit

Full-Stack Kubernetes Operations Review

2026-04-05 Single-node Talos cluster "torvalds" 68 ns / 87 deploy / 24 sts / 13 ds

1 Executive Summary

Area	Score	Summary
Monitoring & Alerting	9/10	33 ServiceMonitors, 47 PrometheusRules (140+ alerts), 10 dashboards, Loki log alerts
Backups	9/10	4-tier Velero (6h/daily/weekly/monthly) to R2, auto-labeling, ZFS snapshots
Secret Management	9/10	1Password Connect, no hardcoded secrets, OnePasswordItem CRDs
Image Security	9/10	All 81 images SHA256-pinned, Renovate automated updates
Priority Classes	8/10	3-tier system (infra 1M / service 100K / batch 1K)
Storage	8/10	ZFS NVMe+SATA, CSI snapshots, Retain reclaim, expansion enabled
Network Policies	6/10	15 namespaces covered, 14 uncovered
Resource Limits	5/10	~40 deployments have limits, ~45 have none
Health Probes	4/10	7 full (L+R+S), 2 partial, ~25 have zero probes
Disaster Recovery	3/10	Backups exist but no WAL archiving, no restore runbook
HA / Redundancy	2/10	Every deployment single-replica, all Recreate strategy
Autoscaling	1/10	No HPA or VPA configured

✅ Strengths

- Full observability: Prometheus + Alertmanager + Grafana + Loki + Tempo
- Velero 4-tier backups with auto-calculated monitoring windows
- Kyverno auto-labels PVCs for backup eligibility
- ZFS monitoring: ARC, L2ARC, SMART, NVMe, pool health, scrub
- PagerDuty with severity routing & inhibition rules
- All 81 images SHA256-pinned with Renovate
- ArgoCD `Delete=false` on databases

⚠️ Critical Gaps

- ~25 deployments have zero health probes
- ~45 deployments have no resource limits
- No WAL archiving — RPO up to 6 hours for databases
- No disaster recovery runbook or restore testing
- Single PagerDuty receiver (no failback)
- 12.5Ti of data with no backup (media, logs, metrics)
- Only Dagger sends traces to Tempo

2 Phase 0: Health Probes & Resource Limits (P0)

2.1 Add Health Probes

7 deployments have full probes. ~25 have zero. Gold standard: `bugsink/index.ts:271--286`.

Deployment	File	Port	Type
birmel	resources/birmel/index.ts	4111	TCP
freshrss	resources/freshrss.ts	80	HTTP `/i/`
plex	resources/media/plex.ts	32400	TCP
tautulli	resources/media/tautulli.ts	8181	TCP
syncthing	resources/syncthing.ts	8384	HTTP `/rest/noauth/health`
homeassistant	resources/home/homeassistant.ts	8123	TCP
redlib	resources/frontends/redlib.ts	8080	TCP
sonarr	resources/torrents/sonarr.ts	8989	HTTP `/ping`
radarr	resources/torrents/radarr.ts	7878	HTTP `/ping`
prowlarr	resources/torrents/prowlarr.ts	9696	HTTP `/ping`
bazarr	resources/torrents/bazarr.ts	6767	TCP
overseerr	resources/torrents/overseerr.ts	5055	TCP
maintainerr	resources/torrents/maintainerr.ts	6246	TCP
qbittorrent	resources/torrents/qbittorrent.ts	8080	TCP
whisperbridge	resources/torrents/whisperbridge.ts	8080	TCP
postal (web)	resources/mail/postal.ts	5000	TCP
plausible	resources/analytics/plausible.ts	8000	HTTP `/api/health`
clickhouse	resources/analytics/clickhouse.ts	8123	HTTP `/ping`
golink	resources/golink.ts	8080	TCP

Skip: ddns, recyclarr, gickup, better-skill-capped-fetcher (cron/periodic, no HTTP port).
Fix partial: mcp-gateway and temporal-ui need startup probes added.

2.2 Add Resource Limits

Deployment	CPU req/lim	Mem req/lim	Rationale
birmel	200m/1000m	256Mi/1Gi	Discord bot + AI + SQLite
golink	50m/200m	64Mi/256Mi	Lightweight Go service
gickup	100m/500m	128Mi/512Mi	Periodic git operations
scout (x2)	100m/500m	256Mi/1Gi	Discord bot + Riot API
sentinel	200m/1000m	256Mi/1Gi	Webhook server + AI
ha-automation	100m/500m	128Mi/512Mi	HA workflow runner
status-page	50m/250m	128Mi/512Mi	Hono API + SQLite
freshrss	100m/500m	128Mi/512Mi	PHP application
plex	500m/4000m	1Gi/8Gi	Transcoding + GPU
tautulli	50m/250m	128Mi/512Mi	Python web app
prowlarr	50m/500m	128Mi/512Mi	LinuxServer indexer
syncthing	200m/1000m	256Mi/1Gi	File sync, IO heavy
redlib	50m/250m	64Mi/256Mi	Rust proxy, stateless
pokemon	500m/2000m	512Mi/4Gi	GPU emulation
starlight-karma-bot	50m/250m	128Mi/512Mi	Discord bot
ddns	10m/100m	32Mi/128Mi	Periodic DNS updater

Deployment	CPU req/lim	Mem req/lim	Rationale
plausible	100m/500m	256Mi/1Gi	Elixir web app
recyclarr	50m/250m	64Mi/256Mi	Cron config updater
qbt gluetun sidecar	50m/500m	128Mi/512Mi	VPN — currently 0
plex/qbt exporters	10m/100m	32Mi/128Mi	Metrics — currently 0
k8s-event-exporter	50m/200m	64Mi/256Mi	Event collector

> **No ResourceQuotas**
>
> ResourceQuotas previously caused etcd event storms. Per-pod limits only.

2.3 Create `withHealthProbes()` Helper

Add to `misc/common.ts`. TCP default, HTTP GET if path provided. Startup: 30 failures @ 10s = 5min. Liveness: 30s period. Readiness: 10s period.

3 Phase 1: Network Security & Monitoring Gaps (P1)

3.1 Network Policies (14 Uncovered Namespaces)

Follow bugsink pattern: `KubeNetworkPolicy` with ingress from Tailscale/CF + egress to DNS + specific backends.

Namespace	Ingress From	Egress To	Pri
golink	Tailscale	DNS only	High
freshrss	Tailscale + CF tunnel	DNS + feeds (80/443)	High
gickup	(none)	GitHub/GitLab + DNS	High
home (HA)	TS + CF + LAN 192.168.1.0/24	IoT + DNS + Sentry	High
tasknotes	Tailscale	DNS + external HTTPS	Med
scout	Prometheus only	Riot API + Discord + S3 + DNS	Med
starlight-karma-bot	(none)	Discord + DNS	Med
redlib	Tailscale	Reddit + DNS	Med
temporal	TS (gRPC) + intra-ns	PostgreSQL + DNS	Med
pokemon	Tailscale + CF	DNS	Low
s3-static-sites	CF tunnel	S3 + DNS	Low
better-skill-capped	(none)	External HTTPS + DNS	Low
grafana-db	Prometheus ns	(none)	Low

3.2 Missing PrometheusRules

Gap	Priority	Notes
PostgreSQL Operator health	P0	Connections, replication lag, vacuum, locks
Temporal workflow failures	P1	Execution errors, stuck workflows, namespace health
cert-manager renewal	P1	Certificate expiration alerts
Kyverno policy violations	P2	Silent failures currently
Absent scrape targets	P2	ServiceMonitor target disappears
Per-PVC disk usage	P2	Individual volume filling beyond ZFS pool alerts

3.3 Missing ServiceMonitors

Only 9 custom ServiceMonitors. Deployments with metrics capability but no scraping: temporal-server (port 9090), clickhouse, tautulli.

3.4 Alertmanager Failover

Currently PagerDuty only. Add Slack or email (via Postal) as fallback receiver.

4 Phase 2: Backup & DR Hardening (P2)

4.1 Disaster Recovery Runbook

Create `packages/homelab/docs/disaster-recovery.md` covering:

Section	Content
RTO/RPO targets	Infrastructure: 1h/6h. Services: 4h/24h. Media: best-effort
Velero restore	Single namespace and full cluster procedures
PostgreSQL	PVC snapshot restore (no PITR without WAL)
Bootstrap	Talos secrets, 1Password creds, ZFS pools, ArgoCD install
Testing	Quarterly restore drills

4.2 PostgreSQL WAL Archiving

Currently NO WAL archiving. RPO = last PVC snapshot (up to 6h data loss). Configure `archive_command` for continuous WAL shipping to R2.

Affected: bugsink-postgresql, grafana-postgresql, plausible-postgresql, temporal-postgresql.

4.3 Database Password Backup

postgres-operator auto-generates passwords into K8s secrets. After total cluster loss these may not survive restore. Store generated passwords in 1Password.

4.4 Orphaned PV Cleanup

`pgdata-windmill-postgresql-0` in Released state. Investigate and delete.

5 Phase 3: Long-Term Hardening (P3)

5.0.1 Tracing Coverage

Only Dagger sends traces to Tempo. Add OTLP env vars to: scout, tasknotes, status-page, sentinel, birmel, mcp-gateway.

5.0.2 PodDisruptionBudgets

0 PDBs in cdk8s code. Add for ArgoCD (Helm), Prometheus (Helm), Home Assistant, Temporal. Use `maxUnavailable: 1`.

5.0.3 Kyverno Policy Expansion

Currently 1 policy. Add: require resource requests, require security context, enforce image registries, prevent privilege escalation.

5.0.4 Missing Dashboards

Have 10, missing: PostgreSQL health, Temporal workflows, Loki ingestion rate, cert-manager status.

5.0.5 Storage Capacity Alerts

No alerts for ZFS pool approaching full. Add 80%/90% thresholds.

5.0.6 mTLS / Service Mesh

No inter-service encryption. Consider Cilium mTLS for sensitive paths (databases, secrets).

6 Full Audit Matrix

Deployment	Probes	Res.	SvcMon	NetPol	Backup	Security
bugsink	L+R+S	Y	–	Y	Y	nonRoot, noPE
tasknotes	L+R+S	Y	Y	–	Y	writable FS
temporal-server	L+R+S	Y	–	Y	–	nonRoot
scout	L+R+S	–	Y	–	Y	writable FS
sentinel	L+R+S	–	–	Y	Y	writable FS
status-page	L+R+S	–	Y	–	Y	writable FS
ha-automation	L+R+S	–	Y	–	–	writable FS
temporal-ui	L+R	Y	–	Y	–	nonRoot
mcp-gateway	L+R	Y	–	Y	–	nonRoot
sonarr	–	Y	–	Y	Y	LS defaults
radarr	–	Y	–	Y	Y	LS defaults
bazarr	–	Y	–	Y	Y	LS defaults
overseerr	–	Y	–	Y	Y	LS defaults
maintainerr	–	Y	–	Y	Y	LS defaults
qbittorrent	–	partial	Y	Y	Y	gluetun=priv
whisperbridge	–	Y	–	Y	–	LS defaults
postal (x3)	–	Y	Y	Y	Y	nonRoot
clickhouse	–	Y	–	–	Y	nonRoot
plausible	–	Y	–	Y	Y	nonRoot
homeassistant	–	Y	partial	–	Y	privileged
plex	–	partial	Y	Y	Y	privileged
birmel	–	–	–	Y	Y	writable FS
golink	–	–	–	–	Y	custom user
gickup	–	–	Y	–	Y	custom user
freshrss	–	–	–	Y	Y	LS defaults
tautulli	–	–	–	Y	Y	none
prowlarr	–	–	–	Y	Y	LS defaults
syncthing	–	–	–	Y	Y	none
redlib	–	–	–	–	–	none
pokemon	–	GPU	–	–	Y	LS defaults
starlight-karma-bot	–	–	–	–	Y	writable FS
recyclarr	–	–	–	Y	Y	LS defaults
ddns	–	–	–	–	–	LS defaults
better-skill-capped	N/A	Y	–	–	–	none

Green = good coverage Yellow = partial Red = needs work L=liveness R=readiness S=startup LS=LinuxServer PE=privilege escalation

7 Backup Coverage

Data Category	Size	Backed Up	Method / Notes
App configs (<200GB)	~500Gi	Yes	Velero PVC snapshots
PostgreSQL databases	~72Gi	Yes	PVC snapshots only (no WAL = no PITR)
MariaDB (postal)	32Gi	Yes	PVC snapshots
Media (plex, qbt)	11Ti	No	>200GB auto-exclusion
Minecraft worlds	384Gi	Varies	Some under 200GB threshold
Prometheus metrics	256Gi	No	Excluded, ephemeral

Data Category	Size	Backed Up	Method / Notes
Loki logs	128Gi	No	Excluded
SeaweedFS blobs	256Gi	No	>200GB
Dagger build cache	1Ti	No	Ephemeral by design

8 Security Posture

Category	Status
Image pinning	All 58 images SHA256-pinned (6 use `latest` tag, 1 uses branch tag)
RBAC	3 custom ClusterRoles, all read-only or scoped
Privileged containers	8 justified (HA, plex, gluetun, dagger, zfs/smart/nvme)
hostNetwork	homeassistant only (mDNS/HomeKit)
hostPID	None
Secret management	1Password Connect, no hardcoded secrets
TLS	Tailscale (private) + Cloudflare (public) — all encrypted
Image signing / SBOM	Not implemented
mTLS between services	Not implemented
Admission control	Kyverno (1 policy — needs expansion)

9 Grafana Dashboard Audit

9.1 Existing Dashboards (8 Custom)

Dashboard	Status	Coverage
Velero	Working	Backup health, storage, duration (~20 panels)
SMART/Smartctl	Working	Device health, temps, sectors (~15 panels)
Buildkite CI	Working	Kueue queue health, resource sizing (~12 panels)
HA Workflows	Working	Workflow execution, success rate (~10 panels)
Scout for LoL	Working	Discord stats, Riot API, commands (~18 panels)
TaskNotes	Working	Request rate, latency, task ops (~12 panels)
ZFS	**BROKEN**	Code exists (~30 panels) but not provisioned
Gitckup	**BROKEN**	Code exists (~15 panels) but not provisioned

Plus ~12 kube-prometheus-stack defaults (Node Exporter, CoreDNS, API Server, Kubelet, etc.)

> ⚠️ **2 Broken Dashboards**
>
> ZFS and Gitckup dashboards have code but TODO: "grafana is not creating this one". Fix provisioning in `resources/grafana/index.ts`.

9.2 Critical Missing Dashboards

Dashboard	Priority	Notes
ArgoCD	P0	ServiceMonitors enabled — app sync, repo health, operator metrics
Loki	P0	Deployed & collecting — log ingestion rate, error trends, query perf
Tempo	P0	Deployed & collecting — trace ingestion, span count, service maps
PostgreSQL	P1	4 databases — connections, replication lag, vacuum, bloat
Cluster Overview	P1	Capacity, workload distribution, resource allocation
etcd	P1	Alert rules exist — key metrics, operation latency, consensus
Per-PVC Storage	P1	Top PVCs, growth trends, capacity warnings
Temporal	P1	Port 9090 exposed — workflow execution, task queues

9.3 Medium Priority Missing Dashboards

- Redis (ArgoCD enables metrics)
- Postal email (ServiceMonitor exists)
- Dagger CI pipelines
- Media stack (Sonarr/Radarr/Prowlarr)
- Minecraft servers (8 instances)
- Plausible analytics
- SeaweedFS distributed storage
- Tailscale networking
- Cloudflare Tunnel traffic
- cert-manager renewals
- Kyverno policy violations
- NVMe health (exporter exists)
- Promtail log pipeline

> ℹ **Monitoring Utilization: ~60%**
>
> Prometheus, Loki, and Tempo all collect data that has no dashboard. The observability stack is deployed but under-visualized.

10 Version Pinning Audit

10.1 Container Images (versions.ts)

58 total images. **All have SHA256 digests** — good. But:

10.1.1 6 images using `latest` tag

Image	Issue
`redlib/redlib`	`latest\@sha256:...` — no version tag for debugging
`timothyjmiller/cloudflare-ddns`	`latest\@sha256:...`
`boky/postfix`	`latest\@sha256:...`
`library/busybox`	`latest\@sha256:...`
`library/alpine`	`latest\@sha256:...`
`mccloud/bazarr-openai-whisperbridge`	`latest\@sha256:...`

Digest provides immutability, but `latest` makes logs/debugging harder.

10.1.2 1 image using branch tag

`shepherdjerred/golink` uses `main\@sha256:...` — a **branch tag**, not a version. Not stable across rebuilds.

10.1.3 14 images not managed by Renovate

All `shepherdjerred/\*` custom images marked `// not managed by renovate`. Updated manually via CI.

10.2 Tool Versions (mise.toml)

> ⚠️ **Unpinned Runtimes**
>
> Root `.mise.toml`: `bun = "1.3.11"` (good), `rust = "latest"`, `java = "latest"`
> Homelab `mise.toml`: `bun = "latest"`, `python = "latest"`
> Clauderon `rust-toolchain.toml`: `channel = "stable"` (follows latest stable)

10.3 NPM `latest` Tags (12 instances)

Package	Dependency	Type
scout-for-lol (6 subs)	`bun-types: latest`	devDep
starlight-karma-bot	`bun-types: latest`	devDep
tasknotes-server	`\@types/bun: latest`	devDep
toolkit	`\@types/bun: latest`	devDep
webring	`\@types/bun: latest`	devDep
cooklang-for-obsidian	`obsidian: latest`	devDep

10.4 NPM Caret Ranges (~350 deps)

Standard `\^` ranges across all packages. Notable loose ones: `typescript: "\^6"` (20+ packages), `gray-matter: "\^4"`, `react: "\^19"`. Mitigated by 20 `bun.lock` files. 5 intentional exact pins (lodash, react-native, pdfjs-dist, discord-player, grafana-sdk).

10.5 Other Findings

- **Docker**: `node:22-slim` in `tools/oci/Dockerfile.obsidian-headless` lacks SHA digest (all others digest-pinned)
- **Terraform**: 4 providers use `\~> X.0` caret ranges (standard for TF)
- **CI tools**: `.buildkite/scripts/setup-tools.sh` pins all 13 tools to exact versions (excellent)

10.6 Version Pinning Summary

Category	Count	Pinned	Issues
Container images	58	All digests	6 `latest` tag, 1 branch tag
Helm charts	17	All exact	None
Tool versions (mise)	4	1 exact	rust, java, python = `latest`
Rust toolchain	1	`stable`	Not version-pinned

Category	Count	Pinned	Issues
NPM `latest`	12	**None**	bun-types, @types/bun, obsidian
NPM caret `\^`	~350	Lock file	Standard, bun.lock mitigates
NPM exact	5	Exact	Intentional
Dagger constants	~15	All exact	None
CI tools (Buildkite)	13	All exact	Excellent
Docker base images	4	3 digest	node:22-slim loose
Terraform providers	4	Caret	Standard for TF
K8s API versions	All	Stable	None